

Threat Modelling Agentic Architecture

A customer support agentic architecture

By Akansha Kesharwani Jun 26, 2026

Traditional Appsec vs Agentic AI Systems Threat Modelling

Traditional Applications

Protect APIs
Protect databases
Validate user input
Secure backend services
RBAC for users
Monitor API activity

Agentic AI Systems

Protect prompts and agent instructions
Protect RAG knowledge stores
Validate user input **and** retrieved context
Secure tools, MCP servers, and external APIs
RBAC for users **and** agents
Monitor agent reasoning, tool usage, and approval workflows

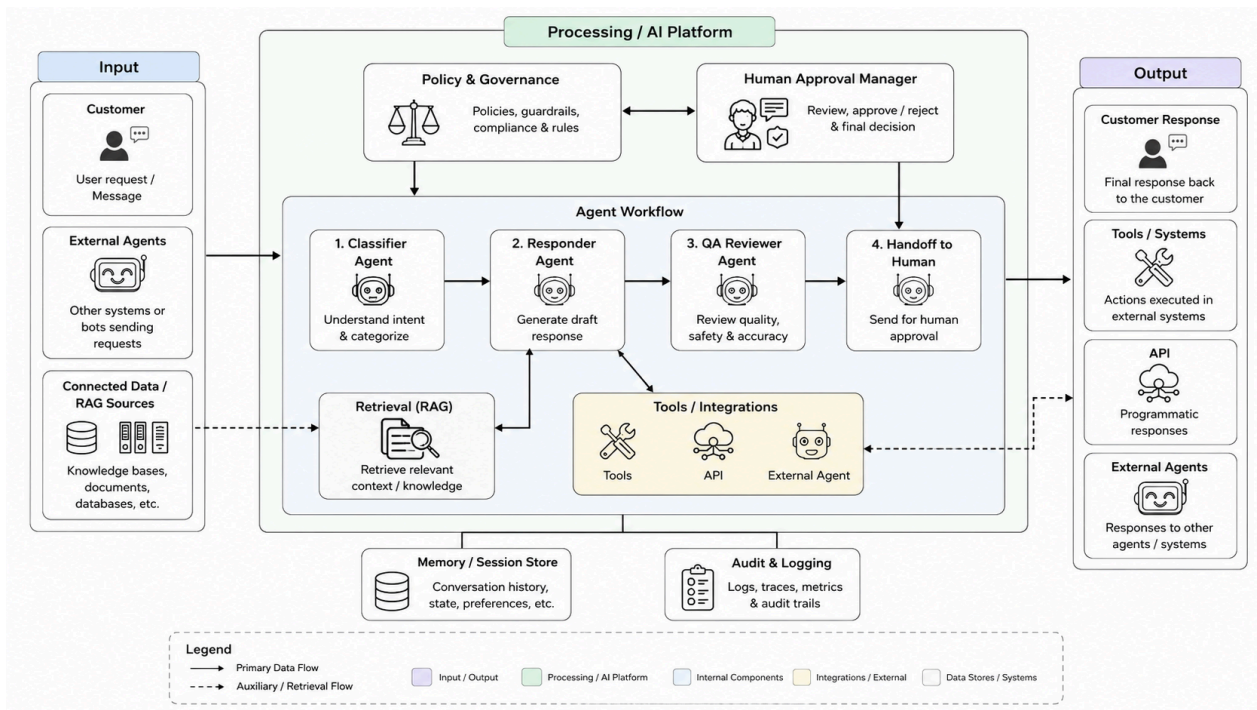
Define the Purpose

The initial step before starting any threat modelling is defining the purpose and assets and answer some of the questions like:

- What are we doing?
- What are we building?
- What do each component in the architecture do?
- What are the assets?
- What do we need to secure?

Customer Support Chatbot

Agentic AI System Architecture



Ask questions from stakeholders before proceeding to threat modelling the architecture:

Question

What business problem does this AI system solve?
Who are the users?
What would happen if the system was unavailable?
What would happen if the system gave wrong answers?
Are there regulatory requirements?
What actions can the system perform?

Why

Understand mission and criticality
Identify threat actors and entry points
Determine availability requirements
Determine integrity requirements
Identify compliance constraints
Determine potential impact

For this architecture some questions can be like:

- Can the agent only answer questions?
- Can it create tickets?
- Can it send emails?
- Can it modify databases?

Data Flow Diagram

Questions to ask before building the data flow diagram:

Question

What triggers the workflow?
What components process the request?
What data stores exist?
What external services are used?
What data is exchanged?
Is data stored or transient?

Why

Identify entry points
Identify processes
Identify storage assets
Identify external dependencies
Define data flows
Identify persistence risks

Are humans involved?

How does the classifier decide intent?

What context is retrieved from RAG?

What tools can the responder invoke?

Can tools modify data or only read data?

What does the QA reviewer validate?

When is human approval required?

Identify manual approval points

Understand decision logic

Understand data exposure

Understand external actions

Determine impact level

Understand security controls

Understand governance

Sample questions for this architecture:

- Does the responder agent have direct access to all tools?
- Can QA reviewer agent call tools?
- Does human approval happen for every response or only high-risk responses?



Component

Purpose

Customer	Customer reaches the support to report any issue. Send a request and receive a response.
Classifier Agent	Read incoming email or messages. Categorizes intent and routes requests
Responder Agent	Writes a draft response
QA Reviewer Agent	Checks whether the response is correct, professional, safe, and doesn't leak information.
Human Manager	The human manager reviews important replies before sending them to the customer.
Tools/ APIs / External Agent	Call tools, API, agents required to perform any third party action
RAG Store	Contains organizations knowledge base, policies and data.

DFD Components

External Entities

- E1 Customer
- E2 External Agent
- E3 API / Tool Provider

Processes

- P1 Classifier Agent
- P2 Responder Agent
- P3 QA Reviewer Agent
- P4 Human Approval Manager

Data Stores

- D1 Memory Store
- D2 RAG Knowledge Base
- D3 Audit Logs

Data Flows

- F1 Customer Request
- F2 Classification Result
- F3 Context Retrieval Query
- F4 Retrieved Context
- F5 Tool/API Request
- F6 Tool/API Response
- F7 Draft Response
- F8 QA Decision
- F9 Human Approval Decision
- F10 Final Response
- F11 Audit Events

Asset Inventory

Question

Why

What information would hurt the business if leaked?

Confidentiality

What information must remain accurate?

Integrity

What systems must always be available?

Availability

What credentials exist?

Authentication risks

What AI-specific assets exist?

Agent security

What decisions affect customers?

Business impact

Where are system prompts stored?

Prompt security

What instructions guide agents?

Agent integrity

What knowledge sources feed the RAG?

Data poisoning analysis

Are embeddings stored?

Sensitive AI asset

Are conversations retained?

Privacy concerns

Are tool permissions restricted?

Agent abuse concerns

For this architecture:

- Are customer prompts stored?
- Are QA decisions logged?
- Are approval records retained?
- Are tool credentials stored centrally?

Asset Type	Asset	Why It Is Important	Potential Impact if Compromised
Business Asset	User Request / Prompt	Contains customer instructions, questions, and business context that drive agent decisions.	Exposure of sensitive customer information, privacy violations, leakage of proprietary data.
Business Asset	Final Response	Represents the official output delivered to the customer.	Incorrect, manipulated, or malicious responses could damage trust, create legal exposure, or lead to business decisions based on false information.
Business Asset	Draft Response	Intermediate output generated before QA and human review.	Disclosure may reveal internal reasoning, confidential data, or incomplete recommendations.
Business Asset	RAG Knowledge Base Content	Contains organizational knowledge used to answer customer requests.	Leakage of proprietary information, intellectual property loss, exposure of confidential documents.
Business Asset	Human Review Decisions	Approval/rejection decisions influence final responses.	Unauthorized modifications could bypass controls or approve harmful responses.
AI Asset	Classifier Agent Instructions	Determines how requests are categorized and routed.	Misclassification could route requests incorrectly, trigger wrong workflows, or bypass safeguards.

AI Asset	Responder Agent Instructions	Governs how responses are generated and how tools are used.	Manipulation may result in unsafe actions, data leakage, or unauthorized tool usage.
AI Asset	QA Reviewer Agent Instructions	Defines review and validation criteria before approval.	Weakening review logic may allow harmful, inaccurate, or policy-violating outputs.
AI Asset	Agent Decision Logic	Internal reasoning used to determine next actions and tool usage.	Attackers may influence workflows, bypass controls, or alter system behavior.
AI Asset	Context Retrieved from RAG Store	Provides supporting information for response generation.	Poisoned or manipulated context can cause inaccurate or malicious responses.
AI Asset	Tool Invocation Requests	Commands sent from the responder agent to external tools/APIs.	Unauthorized actions, excessive API usage, data exfiltration, or abuse of connected systems.
AI Asset	Tool Results	Data returned from tools and external agents.	Malicious or tampered outputs may influence downstream decisions and responses.
Information Asset	Conversation Context	Aggregated request history and retrieved information used during processing.	Exposure can reveal customer data, internal workflows, or confidential information.
Information Asset	Category / Intent Data	Classification results used for routing and processing.	Incorrect modification may trigger unintended workflows or responses.
Information Asset	Approval Status (Approved/Rejected)	Controls progression from review to customer-facing output.	Unauthorized changes may bypass human oversight or block legitimate responses.
Technical Asset	RAG Store	Persistent repository storing retrieval data used by agents.	Data corruption, deletion, poisoning, or unauthorized access impacts response quality and confidentiality.
Technical Asset	External Tools / APIs	Perform actions and provide information used by the responder agent.	Compromise may lead to malicious outputs, unauthorized actions, or service disruption.
Technical Asset	Agent-to-Agent Communications	Data exchanged between classifier, responder, QA reviewer, and approval workflow.	Interception or tampering may alter decisions, responses, or workflow execution.

Technical Asset	Agent Workflow State	Tracks progress through classification, retrieval, review, and approval stages.	Manipulation could skip controls, repeat actions, or disrupt processing.
Security Asset	API Credentials / Authentication Tokens	Enable access to external tools, APIs, and data sources.	Unauthorized access to connected systems, data theft, privilege abuse.
Security Asset	Access Control Rules	Define what agents, reviewers, and tools can access.	Privilege escalation, unauthorized data access, bypass of security controls.
Security Asset	Audit Logs	Record actions taken by agents, reviewers, and tools.	Loss of forensic evidence, inability to investigate incidents, compliance issues.

Some of the high priority assets are:

- User Requests / Prompts
- RAG Store & RAG Data
- Agent Instructions (Classifier, Responder, QA)
- Tool/API Credentials
- Tool Invocation Requests
- Final Response
- Human Approval Decisions
- Audit Logs

Draw Trust Boundaries

Question	Why
Which components are owned by us?	Internal vs external
Which components are third-party?	Supply chain risks
Where does user input enter?	Untrusted input
Where do external APIs interact?	External trust boundary
Where do humans make decisions?	Human trust boundary

Does authentication occur anywhere?

Does privilege level change anywhere?

Can external data influence agent behavior?

Can tool output influence future decisions?

Can RAG content be modified by users?

Can agents access systems with different privileges?

Identity boundary

Authorization boundary

Prompt injection analysis

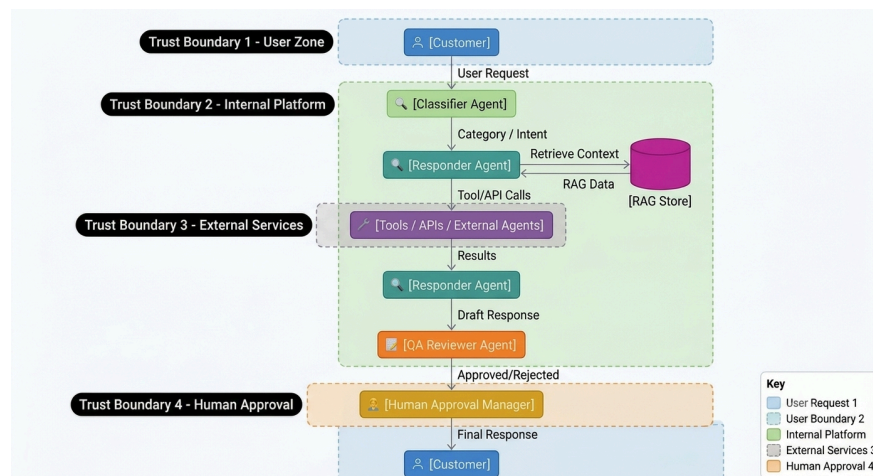
Tool poisoning risks

Knowledge poisoning

Privilege escalation

Some questions based on this architecture:

- Is RAG managed internally?
- Are tools third-party SaaS services?
- Is the human approver inside the company?
- Can tool outputs be trusted?
- Does data change ownership here?
- Can one component manipulate another?
- Is input validated?
- Is there authentication?



Identify any existing security controls implemented before proceeding for the threat enumeration.

Threat Enumeration

ID	Component	Threat Category	Threat	Attack Scenario	Impact
T01	Customer → Classifier Agent	Spoofing	User Identity Spoofing	Attacker impersonates a legitimate customer and submits requests.	Unauthorized access to system capabilities.
T02	Customer → Classifier Agent	Denial of Service	Prompt Flooding	Attacker submits excessive requests or oversized prompts.	Resource exhaustion and service degradation.
T03	Classifier Agent	Tampering	Intent Manipulation	Carefully crafted prompts cause misclassification of intent.	Incorrect workflow execution.
T04	Classifier Agent	Elevation of Privilege	Routing Bypass	Malicious input tricks the classifier into accessing privileged workflows.	Unauthorized operations.
T05	Responder Agent	OWASP LLM01	Direct Prompt Injection	The user embeds instructions to ignore system behavior and reveal data.	Security policy bypass.
T06	Responder Agent	OWASP LLM06	Excessive Agency	Agent performs actions beyond intended scope.	Unauthorized actions.
T07	Responder Agent	Information Disclosure	Sensitive Data Leakage	Agent exposes internal information in responses.	Confidentiality breach.

T08	Responder Agent	Repudiation	Untraceable Decisions	Agent actions are not logged sufficiently.	Inability to investigate incidents.
T09	Responder Agent	MITRE ATLAS	Goal Hijacking	Attacker manipulates agent objective through prompts.	Unintended behavior.
T10	Responder Agent	OWASP Agentic AI	Agent Workflow Manipulation	User influences execution path of the workflow.	Bypass of intended safeguards.
T11	RAG Store	Tampering	Knowledge Base Poisoning	Malicious documents inserted into RAG corpus.	Incorrect or malicious responses.
T12	RAG Store	Information Disclosure	Unauthorized Retrieval	Sensitive documents are retrieved without authorization.	Confidential information exposure.
T13	RAG Store	Denial of Service	Retrieval Disruption	Corrupting indexes or data prevents retrieval.	Reduced system functionality.
T14	RAG Store	MITRE ATLAS	Data Poisoning	Adversary alters retrieval content to influence model outputs.	Persistent manipulation of responses.
T15	RAG Data Flow	OWASP LLM02	Indirect Prompt Injection	Retrieved documents contain hidden instructions affecting the agent.	Agent behavior manipulation.
T16	Tool/API Calls	Tampering	Tool Request Manipulation	Requests sent to tools are modified.	Unauthorized tool execution.
T17	Tool/API Calls	Information Disclosure	API Credential Exposure	API keys or tokens are leaked.	Unauthorized access to external services.
T18	Tool/API Calls	Elevation of Privilege	Tool Abuse	Agent invokes privileged APIs without proper authorization.	Unauthorized business actions.
T19	Tool/API Calls	OWASP Agentic AI	Excessive Tool Access	Agent has access to more tools than required.	Expanded attack surface.

T20	Tool/API Calls	MITRE ATLAS	Tool Exploitation	Attacker uses prompts to force unintended tool execution.	Abuse of connected systems.
T21	External Tools/APIs	Tampering	Malicious Tool Response	External service returns manipulated data.	Incorrect decision making.
T22	External Tools/APIs	Supply Chain	Compromised Third-Party Service	Tool provider is compromised.	Malicious outputs and data theft.
T23	External Tools/APIs	Information Disclosure	Sensitive Data Sent to External Tool	Confidential data included in tool requests.	Data leakage.
T24	External Tools/APIs	Denial of Service	Dependency Outage	External tool becomes unavailable.	Workflow interruption.
T25	Responder Agent ← Tool Results	OWASP Agentic AI	Tool Output Injection	Tool response contains malicious instructions interpreted by agent.	Agent compromise.
T26	Responder Agent ← Tool Results	Tampering	Result Manipulation	Tool output altered before reaching agent.	Incorrect responses.
T27	QA Reviewer Agent	Tampering	Review Logic Manipulation	QA criteria are altered or bypassed.	Unsafe outputs approved.
T28	QA Reviewer Agent	OWASP Agentic AI	Reviewer Bypass	Workflow skips QA validation.	Loss of quality and security checks.
T29	QA Reviewer Agent	Information Disclosure	Review Data Exposure	Draft responses expose sensitive information.	Confidentiality breach.
T30	Human Approval Manager	Spoofing	Reviewer Impersonation	Unauthorized user approves responses.	Unapproved content reaches customer.
T31	Human Approval Manager	Repudiation	Approval Denial	Reviewer disputes having approved content.	Lack of accountability.

T05	Direct Prompt Injection	High	High	Critical	Input validation, prompt isolation, instruction hierarchy, guardrails, output filtering
T15	Indirect Prompt Injection via RAG	High	High	Critical	Content sanitization, retrieval filtering, document trust scoring, context separation
T11/T14	RAG Poisoning / Data Poisoning	Medium	High	High	Controlled ingestion pipeline, document approval process, integrity checks, versioning
T18/T20	Tool Abuse / Excessive Agency	High	High	Critical	Least privilege, tool allowlists, authorization checks, human approval for sensitive actions
T25	Tool Output Injection	High	High	Critical	Treat tool output as untrusted, output sanitization, structured parsing
T37	QA/Human Approval Bypass	Medium	High	High	Workflow enforcement, approval state validation, segregation of duties
T17	API Credential Exposure	Medium	High	High	Secrets manager, key rotation, vault integration, short-lived tokens
T07/T34	Sensitive Data Leakage	High	High	Critical	Data classification, output filtering, redaction, DLP controls
T39	System Prompt Disclosure	High	Medium	High	Prompt compartmentalization, prompt shielding, output filtering
T12	Unauthorized RAG Retrieval	Medium	High	High	Document-level RBAC, retrieval authorization checks

T22	Compromised External Tool	Medium	High	High	Vendor assessment, response validation, sandboxing, monitoring
T21	Malicious Tool Response	Medium	High	High	Trust verification, schema validation, response integrity checks
T30	Reviewer Impersonation	Medium	High	High	MFA, strong authentication, approval audit logs
T33	Reviewer Social Engineering	Medium	High	High	Training, dual approval for high-risk actions, escalation procedures
T04	Routing Bypass	Medium	Medium	Medium	Intent validation, workflow authorization controls
T03	Intent Manipulation	High	Medium	High	Confidence thresholds, secondary validation, fallback workflows
T10	Agent Workflow Manipulation	Medium	High	High	Workflow constraints, state validation, policy enforcement
T32	Approval Decision Manipulation	Medium	High	High	Signed approvals, immutable audit logs
T38	Insufficient Audit Logging	Medium	Medium	Medium	Centralized logging, immutable logs, monitoring
T08	Untraceable Agent Decisions	Medium	Medium	Medium	Decision logging, traceability records
T35	Response Manipulation	Medium	High	High	Integrity validation, secure communication channels
T23	Sensitive Data Sent to Tools	High	High	Critical	Data minimization, outbound filtering, allowlisted destinations

T01	User Identity Spoofing	Medium	High	High	Authentication, MFA, session management
T16	Tool Request Manipulation	Medium	High	High	Request signing, integrity validation
T28	QA Reviewer Bypass	Medium	High	High	Mandatory workflow checkpoints, approval enforcement
T36	Workflow Exhaustion DoS	High	Medium	High	Rate limiting, quotas, resource throttling
T02	Prompt Flooding	High	Medium	High	Rate limits, request size limits, WAF protections
T24	External Dependency Outage	Medium	Medium	Medium	Failover providers, retries, graceful degradation
T13	Retrieval Service Disruption	Medium	Medium	Medium	Backup indexes, redundancy, monitoring
T31	Approval Repudiation	Low	Medium	Medium	Immutable audit logs, digital signatures
T09	Goal Hijacking	Medium	High	High	Goal validation, task boundaries, policy constraints
T06	Excessive Agency	High	High	Critical	Action limits, approval gates, least privilege
T19	Excessive Tool Access	High	High	Critical	Tool scoping, role-based permissions
T26	Result Manipulation	Medium	Medium	Medium	Integrity validation, cryptographic signing
T27	QA Logic Manipulation	Medium	High	High	Configuration management, change controls
T29	Review Data Exposure	Medium	Medium	Medium	Access controls, encryption, data minimization

Risk Rating Criteria

Likelihood	Description
High	Easy to execute, publicly known techniques, low attacker effort
Medium	Requires some knowledge, access, or conditions
Low	Difficult to execute or requires significant privileges

Impact	Description
High	Data breach, unauthorized actions, major business disruption
Medium	Limited data exposure or workflow disruption
Low	Minimal business impact

Risk	Criteria
Critical	High Likelihood + High Impact
High	High/Medium combinations
Medium	Medium/Medium or Low/High
Low	Low/Low

Validate the Threat Model

Questions to ask

- Did we miss any components?
- Are all data flows represented?
- Are all external systems included?
- Are there additional privileged users?
- Do these risks reflect the business impact?
- Are any existing security controls missing?

Prioritize Remediation

Not every finding needs immediate action. Prioritize based on risk and effort.

Priority	Threat	Action
P1	Prompt Injection	Implement prompt guardrails
P1	Tool Abuse	Restrict tool permissions
P1	Data Leakage	Add output filtering
P2	RAG Poisoning	Validate ingested documents
P2	API Key Exposure	Move secrets to a vault
P3	DoS	Add rate limiting

Treat the Threat Model as a Living Document

Threat models should evolve with the system.

Update the model when:

- A new AI agent is added
- A new external tool or MCP server is integrated
- The RAG knowledge source changes
- New APIs are introduced
- Autonomous capabilities increase
- New attack techniques emerge (e.g., new OWASP LLM or MITRE ATLAS techniques)
- Major architecture changes occur